

TLP:CLEAR

Honeypot-Based Threat Intelligence

Monthly Report — August 2026

LLM Honeypot Exploitation | ICS VNC Campaign | SNMP Reflection | SSH Botnets |
VPSVAULT Channel Shift | Phishing Trends

Parameter	Value
Reporting period	1-31 August 2026 (2026-08-01 — 2026-09-01 UTC)
Analysis date	1 September 2026
Classification	TLP:CLEAR
Threat level	HIGH
Honeypot nodes	DE, US, RU + IEC-104/VNC (ICS/OT) decoy
Event volume	≈2.06-2.08M attack sessions/requests across all services (+50% MoM)
SSH events	720,374 sessions, 604,549 failed logins, 517 payload downloads
VNC events (ICS)	≈1.30M connections, 1,279,302 password-guessing attempts
LLM abuse (Ollama)	92,241 events, 46.5% of volume from a single source
Malware samples	≈180 unique artifacts (methodology-adjusted estimate)

1. Executive summary

During August 2026 three general-purpose honeypot nodes (Germany, the United States, Russia) plus a separate industrial-segment decoy (IEC-104 protocol, VNC remote desktop, and a device web interface) recorded roughly 2.06-2.08 million attack sessions and requests — up 50% on July. Growth spread across nearly every category, but the largest single contributor (Dionaea/SMB, +129%) is partly a counting artefact rather than a proportional rise in attacks: the same captured malware file, intercepted over a partial SMB transfer, produces a new hash on every broken transfer and is counted as a separate event each time.

The headline of the month is that our open LLM server (Ollama) stopped being a simple scan counter. Through a known vulnerability family, CVE-2024-37032 ("Problama"), attackers ran systematic traversal against cloud credentials, SSRF into cloud metadata services, an attempted SSH key write into the authorized-keys file, and a defacement campaign carrying a ransom note inside a model's system prompt. Targeted reconnaissance of Anthropic-compatible proxies appeared for the first time — operators are hunting for gateways sitting on someone else's API keys. Nearly half the month's volume (46.5%) came from a single source at a sanctioned hosting provider. Operators also began, for the first time, probing the honeypot's authenticity with dedicated verification prompts — a reasonable hypothesis of risk to the entire class of LLM decoys, though not yet an observed effect: traffic volume did not drop.

On the industrial decoy, the VNC password-guessing campaign did not stop — it changed composition. The autonomous system that dominated July went quiet after 21 August, replaced by a broad cloud cluster and a new group of twelve geographically diverse hosts that switched on in sync. Not a single successful authentication was recorded for the month. Separately, the decoy was used three times as an SNMP reflection amplifier against third parties — two of the three episodes (13-16 August) were roughly 33 times larger by volume than the episode previously written up on its own. The IEC-104 industrial protocol received zero external control commands for a third consecutive month: the real entry path into a segment like this remains remote-access tooling, not the operational-technology protocol itself.

In the SSH segment, a new operator took the top spot in brute-force weight; a known dropper channel grew 15.5x; a mimicry campaign repacks its binary on every request to defeat hash-based detection; and the most technically mature campaign of the month combines SSH persistence, a Monero miner, private SSH key theft, and delivery entirely over SFTP — we do not corroborate or use a single-source attribution of this campaign to a known APT group. The Docker-worm operator known from previous reports did not disappear when Docker traffic fell 34% — it moved its primary delivery channel to direct SSH brute-forcing over the same infrastructure, and its current command-and-control server stayed continuously active for the entire 12-31 August window.

For the first time in this monthly series, we include a phishing section. We monitor mailboxes for several partner organizations at their request; in August, eight or more operators worked independently and simultaneously against one of them (versus three in July). The month's throughline is infrastructure rather than technique: landing pages and exfiltration increasingly move onto legitimate third-party SaaS platforms rather than attacker-owned hosting, two delivery channels bypassed sender spoofing entirely in August, and one operator ran a working adversary-in-the-middle proxy in front of a Google login that steals the session cookie and defeats multi-factor authentication.

2. Corrections and amendments

The figure published in our July 2026 report — "193,552 VNC password-guessing attempts" — was in fact a count over the first 10 days of the month, not the full month. Recomputing from the complete raw log gives the real July volume: 1,218,442 attempts. Any comparison describing a multi-fold jump between July and August that relied on the earlier figure is incorrect: a fair comparison of full months shows a moderate increase in absolute terms (see §4), and a more visible one on a per-day basis. The corrected July baseline is used throughout this report.

Separately, we confirm a previously unreported fact: the second stage of the Docker worm described in our June and July reports was in fact detonated in early July. The second stage turned out to be a Mirai-family DDoS bot rather than a cryptominer, as had been assumed at the earlier stage of analysis, and a third link in its command chain was identified. No standalone publication on this campaign was issued; this is a correction of a previously misstated detonation status.

3. Sensor infrastructure

The fleet consists of three general-purpose honeypot nodes (Germany, the United States, Russia) emulating SSH/Telnet, SMB/MSSQL/MySQL/FTP/SIP, the Docker API, MikroTik RouterOS (Winbox), Kubernetes (Kubelet), and an open LLM endpoint (Ollama), plus a separate industrial-segment decoy emulating the IEC-104 protocol, VNC remote desktop, and an ABB device web interface. Public addresses, hosting providers, and internal node identifiers are not disclosed. Every node in the fleet ran through August with no downtime visible to attackers; the German LLM decoy delivered its first full calendar month of data (it was not online from the start of July), making August the first fully comparable three-node month for that service.

4. Volume summary

Total attack sessions and requests across the three general-purpose nodes for August ran roughly 2.06-2.08 million, versus $\approx$ 1.37 million in July (+50%). SSH (Cowrie), exact counters:

Metric	DE	US	RU	August	July	Δ
Sessions	337,790	206,901	175,683	720,374	657,706	+9.5%
Successful logins	9,295	1,823	4,304	15,422	17,674	-12.7%
Failed logins	280,295	181,864	142,390	604,549	554,964	+8.9%
Shell commands	8,951	3,980	9,084	22,015	10,437	+111%
Payload downloads	355	162	0	517	351	+47%
SFTP uploads	49	38	0	87	49	+78%
direct-tcpip (proxy)	13,886	739	1,082	15,707	25,792	-39%
Success rate	3.2%	1.0%	2.9%	—	—	—

Session count rose modestly while shell-command volume roughly doubled: bots increasingly carry sessions through to a payload rather than dropping off right after login. Unique SSH sources for the month: roughly 20,000 (July $\approx$ 18,600, +8%). Other services, exact counters:

Service	DE	US	RU	August	July	Δ
Dionaea (SMB/MSSQL/MySQL/FTP/SIP)	620,636	184,998	301,620	1,107,254	484,296	+129%
Docker API	44,488	40,922	37,406	122,816	185,347	−34%
Winbox (MikroTik)	1,783	1,798	10,785	14,366	10,017	+43%
Kubelet (k8s)	1,199	1,278	396	2,873	3,634	−21%

Ollama (LLM): 92,241 events for August — not compared to July, since one node was online for only part of that earlier month. Details — §5. Unique sources: Docker ≈1,450 (July ≈2,480, −41% — the campaign narrowed in participant count while its core stayed the same), Kubelet ≈550, Ollama ≈1,470-1,490.

The Dionaea increase (+129%) is the largest contributor among "other services," but comes with a methodological caveat: partial SMB captures of the same malware file (WannaCry) produce a different hash on every broken transfer, so the raw event counter cannot separate a rise in infected hosts from a change in what gets counted as an event. The volume increase is confirmed by the counter; reading it as a proportional rise in attack intensity is not warranted.

The 34% drop in Docker API volume is not a retreat by the previous operator but a channel shift to direct SSH brute-forcing over the same infrastructure and drop zone; see §8.

Industrial decoy, aggregated from raw logs:

Service	August	July (corrected)	Δ
VNC connections	1,295,134 - 1,304,763	1,256,816	+3-4%
VNC password attempts	1,279,302	1,218,442	+5.0%
SNMP requests	380,315 - 380,412	10,027	×38
Device web interface (HTTPS)	36,319	56,702	−36%
IEC-104, all records	1,730 - 1,812	2,156	−16...20%
— of which external	759	1,081	−30%
— external control commands	0	0	zero for a third consecutive month

The July and August observation windows differ by a few hours, which understates the VNC campaign's intensity growth when read from raw totals: normalized per day, connections rose roughly 9-10% and password attempts roughly 7%. Full breakdown — §6.

5. Headline: LLM honeypot under active exploitation

The Ollama decoy logged 92,241 events for August (exact 30-day counter) from 1,469-1,486 unique sources. 46.5% of the month's total came from a single source — a sanctioned hosting provider (AS210644, registered in Russia) — repeating the identical prompt "What is 3+3?" 12,923 times. The month's significance is not volume but quality: enumeration and model-catalogue inventory remain the dominant event class, but for the first time a working exploitation technique appeared alongside them.

Through the `/api/pull` and `/api/create` endpoints — the CVE-2024-37032 ("Problama") vulnerability family — attackers ran systematic path traversal against cloud credentials: `../../../../root/.aws/credentials`, `root/.config/gcloud/application_default_credentials.json`, `/proc/self/environ`, `/etc/passwd` — targeted secret-hunting rather than vulnerability probing. A separate source hid an SSRF request to AWS/GCP metadata services inside the model-name field. We also observed Go-template injection (`{{readFile "/etc/passwd"}}`), an attempted write into `~/.ssh/authorized_keys` via the model-name field — a key implant, not just a file read — and a probe attempting to overflow the GGUF parser with an abnormally large context-size value.

A separate ransom-style campaign: two sources create models on the compromised server named `gpt-4o:latest` / `claude-3-opus:latest` / `gpt-4:latest` out of a local tinyllama model, whose system prompt is a ransom note carrying a BTC address. A passive check at month-end shows zero transactions: the campaign generates no revenue, but remains a defacement of someone else's infrastructure.

Hunting for Anthropic-compatible proxies is new in August and was entirely absent in July. Hundreds of requests hit paths such as `/v1/messages` and `/anthropic/v1/messages` carrying the characteristic anthropic-version header, targeting models named after Claude Opus and routed through cloud wrappers (Bedrock, OpenRouter). Authorization headers support the hypothesis: a hardcoded default master key belonging to a popular LLM gateway product appears repeatedly, alongside deliberately fake placeholder tokens — operators are systematically checking whether an open LLM port sits in front of a gateway holding someone else's Anthropic API key.

Telemetry on payload purpose points to at least three distinct monetization scenarios for stolen inference — this is an interpretation of prompt intent, not a confirmed business model: a betting bot targeting a prediction market, a source resembling a Chinese-language content farm, and a pipeline whose prompt pattern resembles a companion-chatbot's long-term memory function. Telemetry reliably establishes only the probable purpose of the workload; the business model and data provenance behind it remain a hypothesis.

Industrialization also shows up in the scanning tooling itself: dedicated user-agent strings discover an open endpoint, check that it is alive, assess the quality of the model's response, add it to a pool, and periodically recheck it. Separately, a third-party AI coding agent was observed connecting directly to a captured endpoint — a signal that open LLM servers are already wired into other people's working pipelines, not merely scanned.

By path, `/api/tags` (17,112) and `/api/generate` (11,079) lead, followed by `/api/version` (8,616), `/v1/models` (2,901), `/v1/chat/completions` (2,687) — a signature of industrial endpoint verification (enumerate models → send a control prompt → add to a pool). By model, local models lead — `llama3.1:8b` (10,447), `qwen2.5:7b` (1,570), `codellama:13b` (789) — but the qualitative shift is that attackers are working through the entire

catalogue of the service's paid cloud models (roughly 30 distinct models, 20-36 requests each) — systematic inventory rather than casual probing.

Operators also began, for the first time, checking the honeypot's authenticity with dedicated verification prompts (asking it to name its builder model, testing resistance to prompt injection, asking it to echo back an exact control phrase). The verification requests themselves are confirmed by telemetry; the conclusion that "the honeypot will end up on pool blacklists and the data stream will dry up" is a well-founded risk hypothesis for the entire class of LLM decoys, not an observed effect — there is no drop in traffic and no direct sign of blacklisting in this month's data.

6. ICS decoy: the VNC campaign changed composition, SNMP reflection ran three episodes

The VNC password-guessing campaign (port 5900) ran throughout the month. Corrected for the July error (§2), absolute volume grew moderately: 1,279,302 attempts versus 1,218,442 (+5.0%), but normalized per day — since the two observation windows differ in length — the increase is more visible: roughly 42,117 attempts/day versus 39,305 (+7.2%/day), and connections at 44,380/day versus 40,543 (+9.5%/day). The campaign is not standing still — intensity is rising, even if not explosively.

Its composition, however, changed radically. The autonomous system that dominated July made only three brief appearances and then went completely silent from 21 August: in one of its last active windows (18-20 August) it generated 269,212 attempts, after which the hourly series drops to near zero — either its rented address pool expired, or the operator switched targets (the key open question for September). Round-the-clock load is now carried by a broad cloud cluster (285 addresses across two large Asian cloud providers) — the same addresses were an invisible long tail in July and grew by an order of magnitude over the month to become the campaign's backbone. On top of that, a new group of twelve hosts, each in its own autonomous system and country (including several consumer/residential networks), switched on in sync with the departing operator and kept running for three more days after it disappeared. One of the twelve sits in the same /24 block as SSH brute-force sources observed a month earlier — a fleet-wide recurring source for a second consecutive month.

Password guessing succeeded zero times: no records of successful authentication for the month, no confirmed "password accepted" line in the raw log, and no successful login to the device's web portal.

SNMP reflection (amplification of the decoy's responses against third parties) ran as a series of three episodes:

#	Window (UTC)	Packets	Rate	Spoofed sources
A	13 Aug, 11 min	103,607	≈223 pps	≈20 addresses
B	14-16 Aug, ≈47 h	255,070	≈1.45 pps	9-13 addresses
C	28 Aug, 41 sec	10,837	≈265 pps	848 addresses, 6 /24 blocks in one autonomous system

Episodes A and B together total 358,677 requests — roughly 33 times larger than episode C, which had previously been written up separately, and both ran before mitigations were put in place (the evening of 28 August). The evidence as a whole confirms source-address spoofing: ICMP unreachable replies from the

"sources," no TCP history for any of them, and an arithmetically regular step pattern across generated addresses in one of the ranges — the same tooling signature seen in episode C, tying all three episodes to the same traffic generator. Measured amplification runs roughly 8.03x by response payload size.

The IEC-104 industrial protocol received zero external control commands for a third consecutive month. The top sources of external traffic are a mass internet census of reachable devices — large cloud platforms and well-known research scanners — with no concentration on a single actor. The practical conclusion stands: the real entry vector into a segment like this is not the operational-technology protocol itself, but staff remote-access tooling.

7. SSH and botnets

A new lead SSH brute-force operator. July's top sources were single, unrelated actors; in August, one operator accounted for 21.5% of the fleet's entire SSH brute-force weight — roughly 90 IP addresses across five /24 blocks, present daily throughout the month.

A known dropper channel grew from 139 to 2,163 hits (15.5x): the same address simultaneously brute-forces SSH, delivers payloads, and serves as its own dropper host — with no infrastructure rotation, indicating the operator is not worried about being blocked.

A separate source mimics system daemons: 16+ distinct binaries under names such as telnetd, sshd, kworker, systemd, and dbus. Nearly every URL returns two different hashes between requests — the server repacks the binary on the fly, making hash-based detection against this campaign useless.

The month's largest dropper operator added a second /24 block to an already-known one: three multi-architecture toolsets, a classic Mirai/Gafgyt profile.

The most technically mature campaign of August combines SSH persistence with a Monero miner: uploading a private SSH key, cleaning up competing processes, applying an immutable attribute to the ~/.ssh directory, and delivering entirely over SFTP (five architectures, 27 sshd files with 27 different hashes — a fresh repack per victim). URL-based dropper detection does not work against it by design. We note separately: a label attributing this campaign's files to a known APT group, added to one public malware repository, came from a single reporter's manual retrospective lookup and is not corroborated by independent analysis engines — we do not use that attribution in this report or going forward.

Proxy abuse specialized further: TCP-forwarding volume (direct-tcpip) fell 39%, but instead of thousands of random checks, three consistent operators are active — scraping major web portals, checking the liveness of public DNS resolvers, and a new pattern absent in July — probing for an open SMTP relay on cloud-hosted enterprise mail platforms.

On the node emulating MikroTik RouterOS, a spike using a Russian-language login dictionary ran 13-22 August, resembling in style a brute force carried out by already-infected Russian routers against a dictionary of Russian organization names. This is a working hypothesis, not confirmed by evidence of actual infected hosts: only the source, the spike volume, and the dictionary content are confirmed by the data.

A themed target persists and expands in login dictionaries for a third consecutive month: the username "claudes" appeared 928 times, joined in August by a new entry, "openclaw" (514 times) — bots are deliberately hunting for hosts running deployed AI agents, and the list of targeted names keeps growing.

8. Docker worm / VPSVAULT operator: a channel shift

The 34% drop in Docker API volume (§4) is not a decline in the previous operator's activity but a channel shift. The operator known from previous reports abandoned entirely the address that generated 73.6% of July's Docker traffic (zero events from it in August), and a second address in the same /24 also went quiet after 20 August. The same actor, however, appeared directly in SSH sessions for the first time: the same payload path, the same address block and autonomous system, but a new command-and-control host within that same /24 — a proven pivot between the two vectors.

Weaker signals, not backed by the same level of technical pivoting, suggest the same actor's style is probably present in two more fleet services (the LLM decoy and the MikroTik emulator) — the same type of probing, but without a shared payload, fingerprint, or key tying them to the campaign's core as directly as Docker and SSH are tied together.

Independent confirmation through C2-activity metrics: the operator's current command-and-control server was active continuously across the entire 12-31 August window, dominating the month's C2-activity list by more than an order of magnitude — meaning the campaign ran without pauses from the start of the observation window, not only from the second half of the month as individual service logs alone might suggest.

Separately, an unrelated actor deployed a CPU-only Monero miner in the Docker decoy with no host-escape attempt (no elevated privileges, no host filesystem mount) — a fallback to a Chinese GitHub mirror points to a Chinese-speaking operator. Another actor continues to steal the shadow password file through a read-only host filesystem mount, sharing an HTTP client fingerprint with the main worm operator — which may indicate shared tooling or a shared operator, though the fingerprint match alone does not prove either.

9. Malware pipeline

WannaCry over SMB/Dionaea — a continuous global background of infected hosts hitting 445/tcp; the exact unique-sample count is methodologically disputed (§4 — partial captures of the same file produce different hashes on every broken transfer), but the family itself is reliably confirmed. Behavioral analysis shows that even heavily damaged captured copies remain executable: the damage falls on non-critical resource sections, while the header and code stay intact.

RedTail (see §7): SSH persistence plus a Monero miner, delivery entirely over SFTP, five architectures, 27 repacked copies of the sshd system daemon.

Mirai/Gafgyt family: multi-architecture ELF binaries (August included SPARC and PowerPC architectures), the month's largest dropper operator's drop zones, and the source that mimics system daemons with a fresh repack on every request (§7).

Polymorphic droppers from the VPSVAULT operator — a new technique from a known actor: 50 bash scripts of exactly 1,608 bytes from the current drop zone (a continuation of the July Docker worm, same address block and autonomous system), each containing 12 unique six-character hex names, for 600 URLs total, none repeated. URL and hash blocklisting is ineffective against this; only IP-level blocking works.

Overall estimate for August: roughly 180 unique malware artifacts (a range of 178-192 depending on how partial SMB captures are counted) — a downward, methodology-corrected estimate against earlier internal

draft counts based on simple hash counting. A single point figure within that range should not be stated as fact.

10. Phishing: trends of the month

A new section for this monthly series. We monitor mailboxes for several partner organizations at their direct request; what follows is a generalized picture of themes, techniques, and operator infrastructure, without reference to specific domains, organizations, or recipient addresses.

10.1 Scale

August recorded roughly 40 independent campaigns with a real landing page or malicious payload — out of a substantially larger stream of raw email that includes background B2B spam and an organization's own outbound mail being mistakenly flagged as spoofing. Against one of the monitored organizations, eight or more operators worked independently and simultaneously in August, versus three in July. Overall inbound volume to monitored mailboxes fell 31% day-over-day against July; the count of high-score alerts (after excluding mistakenly flagged self-spoofs) fell 13%.

10.2 Key stories of the month

- A fan-out targeted campaign. One operator ran a "your email/hosting registration has expired" theme and sent personalized mail to several regional mail aliases of one organization, with the subject line customized to each individual recipient.
- An AiTM proxy against a Google login. One operator ran a live reverse proxy in front of the genuine Google sign-in page that steals the session cookie right after the password is entered — multi-factor authentication does not stop this scheme. The campaign arrived through a compromised third-party Google Group, with no sender spoofing at all.
- Business email compromise (BEC) against a finance function. The month's only alert on one monitored mailbox was an invoice-fraud attempt delivered through a compromised legitimate email-service account with a valid DKIM signature. The same subject preset and the same recipient had already appeared in July — a persistent targeted line against the finance function, not a one-off.
- A malware line sharing one sending infrastructure. The same Vietnam-based infrastructure switched its payload format over the course of the month, from an executable inside a fake archive to a JS loader — the sending IP address stayed the same throughout, which is how the two waves were tied together.
- Targeted password harvesting against a single mailbox. One specific mailbox at one organization received five independent attack lines during the month; its address was embedded directly in the URL of every landing page.
- An ongoing brand-impersonation campaign. A Meta/Facebook-branded campaign against an organization in the nonprofit sector has run unchanged in technique since early July, personalized with the organization's name and its social-media page — only the landing-page domains change.

No line we could attribute showed signs of state-aligned targeting: every operator we identified is running commercial commodity phishing against resold lists, with the one distinguishing feature that some operators clearly personalize their mailing around a specific organization or even a specific mailbox.

10.3 Trend: someone else's infrastructure instead of your own

The number of operators simultaneously active against one organization grew from three to eight or more. Landing pages increasingly sit not on attacker-owned hosting but on legitimate cloud platforms — object storage, frontend PaaS providers, IPFS gateways, and CDNs; in August only one operator registered its own domain for a kit, and that domain lasted under five days before the registrar suspended it. Exfiltration moved to the same kind of infrastructure: capture forms are hosted on third-party web-form services, and some operators send stolen data straight into Telegram over the Bot API. There is nothing to block by exfiltration domain in this pattern — the services in use are legitimate public platforms.

Two delivery channels in August dispensed with sender spoofing entirely: mail went out through compromised corporate mailboxes on a legitimate domain and through hijacked third-party Google Groups — message authentication (SPF/DKIM/DMARC) passes cleanly in both cases. Rather than hiding from automated analysis, operators now more often defend against the analysis itself: CAPTCHAs, a CDN's "under attack" mode, slider gates, and blocklists by autonomous system (in some cases including Google and Meta themselves) and by the requester's geography.

11. Recommendations

- Do not expose VNC to the internet. Where remote desktop access to workstations is required, place it behind a VPN with multi-factor authentication. A distributed password-guessing campaign spread evenly across dozens or hundreds of addresses stays under the alerting threshold on every individual IP.
- Aggregate failed login attempts by autonomous system and address block, not IP alone — this month's campaigns show an operator can fully replace its address set while keeping intensity constant.
- The Docker API must never be reachable from the internet; where remote management is required, use TLS with client certificates and an address allowlist.
- Do not expose open LLM servers (Ollama, llama.cpp, and compatible services) without authentication and without restricting the /api/pull and /api/create paths — these paths became the primary vector for traversal and SSRF against cloud credentials in August. Upgrade to an Ollama version that closes CVE-2024-37032.
- Rate-limit outbound SNMP traffic from decoys or devices and enforce a daily response budget for unauthenticated requests — a device that answers an SNMP query from an arbitrary spoofed source address becomes a DDoS amplifier against third parties.
- In segments adjacent to industrial protocols, start inventory work with staff remote-access tooling rather than the OT protocol itself — remote-desktop-surface load in August exceeded external load against the industrial protocol by orders of magnitude.
- Disable SSH password authentication. The bulk of brute-force volume is dictionary attacks, fully neutralized by moving to keys.
- Treat SFTP as an independent malware delivery channel: detection built solely on dropper URLs in shell commands misses binaries uploaded directly over SFTP.
- To defend against session-cookie theft via adversary-in-the-middle proxies, move to hardware security keys (FIDO2/WebAuthn) wherever feasible — a classic one-time code does not stop this scheme.
- Enforce strict DMARC alignment and monitor for compromise of third-party email services (transactional senders, ESP accounts) — this month's BEC campaign against a finance function passed through the valid DKIM signature of a compromised legitimate sender.
- Train staff to recognize individually personalized "your hosting/email/subscription has expired" messages — this was the working technique behind the month's mass fan-out phishing campaign.

12. MITRE ATT&CK

- T1595.002 — Active Scanning: Vulnerability Scanning
- T1190 — Exploit Public-Facing Application
- T1610 — Deploy Container
- T1611 — Escape to Host
- T1110.001 — Brute Force: Password Guessing
- T1021.005 — Remote Services: VNC
- T1021.004 — Remote Services: SSH
- T1046 — Network Service Discovery
- T1105 — Ingress Tool Transfer
- T1027.002 — Obfuscated Files or Information: Software Packing
- T1496 — Resource Hijacking
- T1552.001 — Unsecured Credentials: Credentials In Files
- T1552.005 — Unsecured Credentials: Cloud Instance Metadata API
- T1098.004 — Account Manipulation: SSH Authorized Keys
- T1498.002 — Network Denial of Service: Reflection Amplification

- T0846 — Remote System Discovery (ICS)
- T0888 — Remote System Information Discovery (ICS, General Interrogation)
- T1566.001 — Phishing: Spearphishing Attachment
- T1566.002 — Phishing: Spearphishing Link
- T1539 — Steal Web Session Cookie
- T1585.002 — Establish Accounts: Email Accounts
- T1567 — Exfiltration Over Web Service
- T1090 — Proxy

13. Indicators of Compromise

Indicators below are shown defanged. Machine-readable dumps — iocs.stix2.json (STIX 2.1) and iocs.misp.json (MISP) — ship alongside this report in refanged, working format. Publication of currently live command-and-control infrastructure has been separately approved for this cycle. Addresses or identifiers that could reveal the location or makeup of our own sensors have been excluded from these indicators.

13.1 LLM abuse (Ollama)

Indicator	Context
147[.]45[.]69[.]42 (AS210644, sanctioned)	46.5% of the month's volume; repeated "What is 3+3?" probe
168[.]144[.]135[.]119	Traversal against AWS/GCP cloud credentials via /api/pull
208[.]84[.]103[.]51	Traversal / exploitation attempts
8[.]219[.]90[.]108	Go-template injection ({{readFile "/etc/passwd"}})
156[.]239[.]42[.]225	Attempted write to ~/.ssh/authorized_keys via model name
151[.]231[.]112[.]236	Traversal against id_rsa
136[.]243[.]10[.]183	SSRF against cloud metadata (AWS/GCP)
74[.]80[.]181[.]141, 199[.]217[.]105[.]247	"deadbugz" ransom-style campaign
103[.]124[.]110[.]245, 103[.]124[.]110[.]246	Prediction-market betting bot
BTC: bc1q5xpazlg7q6ph2r6s7tzumd5zyj det6vjzvsqIn	deadbugz campaign wallet — 0 transactions at time of check

13.2 ICS: VNC campaign and SNMP reflection

Campaign core, silent since 21 August: 140[.]235[.]17[.]25/.49/.65, 140[.]235[.]18[.]105/.166, 140[.]235[.]19[.]17, 207[.]174[.]1[.]227-231, 207[.]174[.]2[.]239/.241, 207[.]174[.]3[.]248, 72[.]51[.]57[.]6, 72[.]51[.]59[.]6.

"Heavy dozen" (synchronized activation, each in its own autonomous system and country):

188[.]130[.]208[.]33, 104[.]128[.]190[.]153, 37[.]187[.]3[.]25, 37[.]58[.]131[.]227, 103[.]103[.]245[.]226, 103[.]160[.]37[.]151, 183[.]178[.]3[.]113, 169[.]38[.]135[.]196, 165[.]165[.]142[.]149, 192[.]3[.]154[.]34, 94[.]154[.]43[.]191, 93[.]48[.]225[.]80.

SNMP reflection — addresses spoofed as sources of amplification traffic against the decoy (block unauthenticated SNMP on these and similar devices; do not block the addresses themselves):

185[.]242[.]3[.]3/.200/.202/.203, 43[.]228[.]157[.]74, 45[.]194[.]67[.]120, 45[.]205[.]1[.]231, 5[.]42[.]211[.]96, 152[.]89[.]199[.]131.

13.3 SSH and botnets

The month's lead SSH brute-force operator — blocks 91[.]92[.]40[.]0/24, 91[.]92[.]42[.]0/24, 91[.]92[.]47[.]0/24, 45[.]153[.]34[.]0/24, 45[.]156[.]87[.]0/24. "nerv" dropper channel: 171[.]244[.]44[.]251. System-daemon mimicry: 213[.]232[.]114[.]14. Largest dropper operator: 176[.]65[.]139[.]228:6677, 176[.]65[.]139[.]202, 94[.]154[.]43[.]231:3001, 94[.]154[.]43[.]238. RedTail (SFTP delivery): 130[.]12[.]180[.]51. Other persistent clusters: 195[.]178[.]110[.]0/24, 92[.]118[.]39[.]0/24, 193[.]32[.]162[.]0/24, 2[.]57[.]122[.]0/24, 80[.]94[.]92[.]0/24, 77[.]239[.]124[.]0/24. XMRig container: 64[.]112[.]184[.]210, wallet 8AQRm4ZiDAXwLhiuSAyCBfdQC1MFbQAYkTnqtN3De1pSYrWxXzaMjjMSm2THvviW52tPXTSfgSY6UqJxouc1vVpBN5MuJG, pool pool[.]supportxmr[.]com:3333. Hypothesized self-contained botnet on the MikroTik emulator: 83[.]237[.]93[.]10.

RedTail hashes (SHA-256, multi-architecture sshd copies):

f0aa83bbbd2c75e2f71ec16029ee5fcfad59f3a8efa30a500b815f0f6c18d987 (x86_64) ·
3f3bf218089d1488617d37f8a5116bb2791eb39ce06a1b5bc9a4cdf5e94dd39 (riscv) ·
8e1a67a5c03b3cd818f046c7a1605afccc0ee5ce437a0d099881f1872b54bc70 (i686) ·
d1cac82f44b54b0fd244a9e4122811e9ae108a197c7a65a20fd2e7552683e68e (arm8) ·
d70f917e35813a7ae323e6b2b539d6dbbfc3a3a6599f1fed93430b14ca08b141 (arm7). A label attributing these files to a known APT group in one open malware repository is not corroborated by independent engines and is not used here.

13.4 Docker worm / VPSVAULT operator

Current command-and-control server, confirmed live and continuously active for the entire 12-31 August window: 5[.]182[.]210[.]174 (path /ok). Prior, July C2: 5[.]182[.]210[.]61 (not observed in August). Docker-channel executor: 45[.]198[.]224[.]26 (quiet after 20 Aug); 45[.]198[.]224[.]5 (absent all of August). Probably the same operator (not proven to the same pivoting standard): 154[.]90[.]70[.]254 (LLM decoy), 45[.]205[.]1[.]240 (MikroTik emulator). HTTP client fingerprints (JA4H): po11nn060000_46ba010406bc, po11nn050000_2c3038913033. Other live C2s for the month, an order or two of magnitude smaller by volume: 154[.]54[.]100[.]247, 217[.]60[.]195[.]113 (the same C2 flagged in the July report — the campaign never closed), 101[.]33[.]245[.]191, 167[.]86[.]122[.]134.

13.5 Phishing

Sending infrastructure (IP): 36[.]255[.]97[.]120 · 77[.]83[.]39[.]10/.14/.15/.17/.24/.45/.81 ·
198[.]135[.]51[.]150 · 45[.]74[.]252[.]189 · 65[.]181[.]122[.]48 · 152[.]89[.]218[.]91 · 108[.]59[.]4[.]205 ·
66[.]181[.]39[.]225 · 95[.]217[.]203[.]83 · 5[.]230[.]201[.]163 · 5[.]175[.]182[.]215 · 192[.]227[.]144[.]55 ·
172[.]245[.]92[.]100 · 198[.]135[.]55[.]67 · 135[.]181[.]7[.]237 · 136[.]243[.]200[.]190 · 160[.]30[.]136[.]41 ·
160[.]30[.]136[.]11 (malware-line infrastructure, the pivot linking two waves of the same campaign) ·
144[.]31[.]63[.]120 · 204[.]152[.]214[.]27 · 150[.]241[.]230[.]186.

Landing pages and send domains, dedicated operator infrastructure (block the domain outright):

fifapredict[.]live, richiedabie[.]com, hulladolsentenpe[.]top (AiTM proxy in front of the Google login, plus wildcard subdomains impersonating mail/cloud services), v1ad0bv1[.]es, meta-iden[.]com, meta-ids[.]com, meta-mailcontact[.]com, meta-betamax[.]com, meta-securitypage[.]com, facebook-security[.]date, verified-blue-badge[.]com, sellpia247[.]com, st[.]sellpia247[.]com, meta-security-mail[.]com, fb-security-blud[.]netlify[.]app, fb-copyright-page[.]netlify[.]app, facebook-verified-badge[.]center, facebookbadgeapply[.]com, solidfairhubhost[.]com, coredatayfe[.]com, domainswitchmove[.]com, mail[.]logiswebmail[.]top, hatsmtp[.]top, global[.]traders[.]ca, secure[.]jambergmarktber[.]store, project22499886[.]tilda[.]ws.

Compromised legitimate sites used as landing infrastructure — block the specific path, not the domain:

habitatcyprus[.]com, nelsonequity[.]com (kit path /webverify/pageme/fased.html), sameylogistics[.]com, login[.]2cccloud[.]com. Two-stage landing: flix-fox[.]com[.]in → read0nsession[.]es.

Malware-line attachment hashes (SHA-256):

530d00da82a188bd6ff7dc3a1cc0b6216d8f9a279f7d00213bbc68acd09d2f71 ·
 f3cfcbd8c2d33128a836f891791a1743c427f321f538dc208521c371edd03d7f ·
 df7ec7857c3e6c3679ad50c60fbd97f322eca68f1c893c1b9c8ee7aa05a0a656 ·
 b3999441143b2dd9788d4dca2a538c349d68d0f6d3ce4bd61a3fc5c134445307 ·
 0667e9dba7e3bfcd004aa5f50e462a52efd01fa9ddd1c97d533e6db5ee0bc977 ·
 ffaddf3882cdd59a4b685e7215bedee8b4b84f10ae4644d37e937755d8cb6d32 ·
 a601ae5011cec30fd1f3af31830e733e339e59e4bc9e3461cca383c99e06bfa3 ·
 3ed1a5df1dfb1a5a345fdea33b97eff013c3ec08a415b73312b82daa1d13a792 ·
 1219a58a2c598567bad7d06fa7f29769e613e279b5623df6302f2f4bb6594069 ·
 4721cafc6efbf3435a188af4a7e71722c8b647bcdfd4948e8c02a38bc2e7ebd1 ·
 c9826b12efd1a694159e1e2fd7b215045ed85dc92f0a4e52b9639bcbe2277264 ·
 b3c7e130a3a6b609c21175e978d307f8efc9a11c5286e08898e045dbc6352fb4 ·
 ab51b26c0fc15403dae63cf40a28a09bd85c624d5929cddf11537688f1b76f8b ·
 3f746415957b5f2abbce7baeb6edd5232411372a5c1c0c04a319c6bedd8974e9 ·
 bfc48971d3254861637e5e370ff2d522defe0b28d566c7b76c4bea7d7195aaf7.

Sextortion campaign BTC wallets (4 waves, one confirmed payment):

bc1qw6l8m0u9720l7p6l8nw3trcesgt2rxshvr7xrd · bc1q5t0peymgrvzd49e4zgwxxnwrac7n4sc45fufwvr
 (confirmed payment) · 1DFN2R8w1Qos6Cwi4kp68ACZLSHHFeaRFq ·
 bc1qk34llhm32cmj8t3m652wdz884hy565d6skv2de.

Infrastructure hosted on legitimate shared platforms (Formspark, Backblaze B2, Google Cloud Storage, Pipedream, IPFS, Framer, Netlify, Vercel) is deliberately not listed indicator-by-indicator: blocking the platform domain would affect legitimate users of the service, and the specific identifiers (form ID, bucket, CID) rotate between campaigns faster than is useful to publish.